

API Functional Test Scope

Student_Mangement_System

Generated: 2026-07-14 07:40:27 UTC

Testing Tool: PLAYWRIGHT, SELENIUM

Controllers: 4

74
API Endpoints to Test
21
GET Requests
28
POST Requests
15
PUT/PATCH Requests
10
DELETE Requests

Project-Specific API Validation Scope

- All 74 API endpoints respond with correct HTTP status codes for happy-path requests
- POST endpoints validate required fields and return 201 Created with proper Location headers
- Response payloads conform to expected JSON schemas with correct data types
- Error scenarios return appropriate 4xx/5xx status codes with descriptive error messages

Test Case Details

#	Method	Endpoint Path	Business Test Scenario	Validation Assertions	Source
1	POST	/api/auth/register	Successful user registration with valid credentials	['Assert 201 Created status code', 'Validate response body contains user ID and success message', 'Verify user is created in the database (if accessible)', 'Assert no sensitive information like password is returned']	GenericAuthentication
2	POST	/api/auth/register	Registration with an already existing email address	['Assert 409 Conflict or 400 Bad Request status code', 'Validate error message indicates duplicate email']	GenericAuthentication

3	POST	/api/auth/register	Registration with missing required fields (e.g., email, password)	[Assert 400 Bad Request status code', 'Validate error message specifies missing fields']	GenericAuthentication
4	POST	/api/auth/register	Registration with an invalid email format	[Assert 400 Bad Request status code', 'Validate error message indicates invalid email format']	GenericAuthentication
5	POST	/api/auth/register	Registration with a weak password (e.g., too short, common password)	[Assert 400 Bad Request status code', 'Validate error message indicates password policy violation']	GenericAuthentication
6	POST	/api/auth/register	Registration with excessively long input fields (e.g., name, email)	[Assert 400 Bad Request status code', 'Validate error message indicates field length violation']	GenericAuthentication
7	POST	/api/auth/login	Successful user login with valid credentials	[Assert 200 OK status code', 'Validate response body contains an authentication token (JWT, session ID)', 'Verify token has expected claims/structure', 'Assert no sensitive information like password is returned']	GenericAuthentication

8	POST	/api/auth/login	Login with incorrect password for an existing user	[Assert 401 Unauthorized status code', 'Validate error message indicates invalid credentials']	GenericAuthentication
9	POST	/api/auth/login	Login with a non-existent email address	[Assert 401 Unauthorized status code', 'Validate error message indicates invalid credentials (to prevent user enumeration)']	GenericAuthentication
10	POST	/api/auth/login	Login with missing credentials (e.g., empty email or password)	[Assert 400 Bad Request status code', 'Validate error message specifies missing fields']	GenericAuthentication
11	POST	/api/auth/login	Login with an account that is locked or disabled	[Assert 401 Unauthorized or 403 Forbidden status code', 'Validate error message indicates account status']	GenericAuthentication
12	POST	/api/auth/login	Rate limit test: Multiple failed login attempts	[Assert 429 Too Many Requests status code after threshold', 'Verify subsequent requests are blocked for a period']	GenericAuthentication

13	POST	/api/auth/logout	Successful user logout with a valid token	['Assert 200 OK or 204 No Content status code', 'Verify the authentication token is invalidated on the server side (subsequent requests with token fail)']	GenericAuthentication
14	POST	/api/auth/logout	Logout attempt without an active session/token	['Assert 401 Unauthorized or 400 Bad Request status code', 'Validate error message indicates no active session']	GenericAuthentication
15	GET	/api/users	Retrieve all users as an administrator	['Assert 200 OK status code', 'Validate response is a JSON array of user objects', 'Verify response contains expected number of users', 'Assert sensitive information (e.g., passwords) is not exposed']	GenericUserManagement
16	GET	/api/users	Attempt to retrieve all users as a regular authenticated user (unauthorized)	['Assert 403 Forbidden status code', 'Validate error message indicates insufficient permissions']	GenericUserManagement
17	GET	/api/users	Attempt to retrieve all users as an unauthenticated user	['Assert 401 Unauthorized status code', 'Validate error message indicates missing authentication']	GenericUserManagement

18	GET	/api/users/{id}	Retrieve a specific user by valid ID as an administrator	[Assert 200 OK status code', "Validate response body matches the requested user's data", "Verify JSON schema of the user object"]	GenericUserManagement
19	GET	/api/users/{id}	Retrieve own user profile by valid ID as an authenticated user	[Assert 200 OK status code', "Validate response body matches the authenticated user's data"]	GenericUserManagement
20	GET	/api/users/{id}	Attempt to retrieve another user's profile by ID as a regular authenticated user (IDOR)	[Assert 403 Forbidden or 404 Not Found status code', "Validate error message indicates access denied"]	GenericUserManagement
21	GET	/api/users/{id}	Retrieve a user by a non-existent ID	[Assert 404 Not Found status code', "Validate error message indicates user not found"]	GenericUserManagement
22	GET	/api/users/{id}	Retrieve a user by an invalid ID format (e.g., non-numeric, special characters)	[Assert 400 Bad Request status code', "Validate error message indicates invalid ID format"]	GenericUserManagement
23	POST	/api/users	Create a new user with valid data as an administrator	[Assert 201 Created status code', "Validate response body contains the newly created user's ID and data", "Verify user can be retrieved via GET /api/users/{id}"]	GenericUserManagement

24	POST	/api/users	Attempt to create a new user with missing required fields as an administrator	['Assert 400 Bad Request status code', 'Validate error message specifies missing fields']	GenericUserManagement
25	POST	/api/users	Attempt to create a new user with duplicate unique fields (e.g., email) as an administrator	['Assert 409 Conflict or 400 Bad Request status code', 'Validate error message indicates duplicate entry']	GenericUserManagement
26	POST	/api/users	Attempt to create a new user as a regular authenticated user (unauthorized)	['Assert 403 Forbidden status code', 'Validate error message indicates insufficient permissions']	GenericUserManagement
27	PUT	/api/users/{id}	Update an existing user's data with valid information as an administrator	['Assert 200 OK status code', 'Validate response body reflects the updated user data', 'Verify changes are persisted by retrieving the user again']	GenericUserManagement
28	PUT	/api/users/{id}	Update own user profile with valid information as an authenticated user	['Assert 200 OK status code', 'Validate response body reflects the updated user data']	GenericUserManagement
29	PUT	/api/users/{id}	Attempt to update another user's profile as a regular authenticated user (IDOR)	['Assert 403 Forbidden or 404 Not Found status code', 'Validate error message indicates access denied']	GenericUserManagement

30	PUT	/api/users/{id}	Update a user with a non-existent ID	[Assert 404 Not Found status code', 'Validate error message indicates user not found']	GenericUserManagement
31	PUT	/api/users/{id}	Update a user with invalid data types or formats	[Assert 400 Bad Request status code', 'Validate error message specifies validation errors']	GenericUserManagement
32	PUT	/api/users/{id}	Mass Assignment: Attempt to update sensitive, non-updatable fields (e.g., 'isAdmin' flag)	[Assert 200 OK status code (if other fields are valid)', 'Verify that the sensitive field was NOT updated in the database', 'Assert no privilege escalation occurred']	GenericUserManagement
33	DELETE	/api/users/{id}	Delete an existing user by valid ID as an administrator	[Assert 204 No Content or 200 OK status code', 'Verify user can no longer be retrieved via GET /api/users/{id} (should return 404)']	GenericUserManagement
34	DELETE	/api/users/{id}	Attempt to delete a non-existent user	[Assert 404 Not Found status code', 'Validate error message indicates user not found']	GenericUserManagement

35	DELETE	/api/users/{id}	Attempt to delete a user by invalid ID format	['Assert 400 Bad Request status code', 'Validate error message indicates invalid ID format']	GenericUserManagement
36	DELETE	/api/users/{id}	Attempt to delete a user as a regular authenticated user (unauthorized)	['Assert 403 Forbidden status code', 'Validate error message indicates insufficient permissions']	GenericUserManagement
37	GET	/api/products	Retrieve all products with no filters	['Assert 200 OK status code', 'Validate response is a JSON array of product objects', 'Verify response contains expected number of products (if any)']	GenericProductCatalog
38	GET	/api/products	Retrieve all products with pagination (e.g., page=1&size=10)	['Assert 200 OK status code', 'Validate response contains the correct number of items per page', 'Verify pagination metadata (total items, total pages) is correct']	GenericProductCatalog
39	GET	/api/products	Retrieve products filtered by category and price range	['Assert 200 OK status code', 'Validate all returned products match the specified filters']	GenericProductCatalog

40	GET	/api/products/{id}	Retrieve a specific product by valid ID	['Assert 200 OK status code', 'Validate response body matches the requested product's data', 'Verify JSON schema of the product object']	GenericProductCatalog
41	GET	/api/products/{id}	Retrieve a product by a non-existent ID	['Assert 404 Not Found status code', 'Validate error message indicates product not found']	GenericProductCatalog
42	GET	/api/products/{id}	Retrieve a product by an invalid ID format	['Assert 400 Bad Request status code', 'Validate error message indicates invalid ID format']	GenericProductCatalog
43	POST	/api/products	Create a new product with valid data as an authorized user (e.g., admin/seller)	['Assert 201 Created status code', 'Validate response body contains the newly created product's ID and data', 'Verify product can be retrieved via GET /api/products/{id}']	GenericProductCatalog
44	POST	/api/products	Attempt to create a new product with missing required fields	['Assert 400 Bad Request status code', 'Validate error message specifies missing fields']	GenericProductCatalog

45	POST	/api/products	Attempt to create a new product with duplicate unique fields (e.g., SKU)	['Assert 409 Conflict or 400 Bad Request status code', 'Validate error message indicates duplicate entry']	GenericProductCatalog
46	POST	/api/products	Attempt to create a new product with negative price or stock quantity	['Assert 400 Bad Request status code', 'Validate error message indicates invalid value']	GenericProductCatalog
47	POST	/api/products	Attempt to create a new product as an unauthenticated user	['Assert 401 Unauthorized status code', 'Validate error message indicates missing authentication']	GenericProductCatalog
48	PUT	/api/products/{id}	Update an existing product's data with valid information as an authorized user	['Assert 200 OK status code', 'Validate response body reflects the updated product data', 'Verify changes are persisted by retrieving the product again']	GenericProductCatalog
49	PUT	/api/products/{id}	Update a product with a non-existent ID	['Assert 404 Not Found status code', 'Validate error message indicates product not found']	GenericProductCatalog
50	PUT	/api/products/{id}	Update a product with invalid data types or formats	['Assert 400 Bad Request status code', 'Validate error message specifies validation errors']	GenericProductCatalog

51	PUT	/api/products/{id}	Attempt to update a product as an unauthorized user	[Assert 403 Forbidden or 401 Unauthorized status code', 'Validate error message indicates insufficient permissions']	GenericProductCatalog
52	DELETE	/api/products/{id}	Delete an existing product by valid ID as an authorized user	[Assert 204 No Content or 200 OK status code', 'Verify product can no longer be retrieved via GET /api/products/{id} (should return 404)']	GenericProductCatalog
53	DELETE	/api/products/{id}	Attempt to delete a non-existent product	[Assert 404 Not Found status code', 'Validate error message indicates product not found']	GenericProductCatalog
54	DELETE	/api/products/{id}	Attempt to delete a product by invalid ID format	[Assert 400 Bad Request status code', 'Validate error message indicates invalid ID format']	GenericProductCatalog
55	DELETE	/api/products/{id}	Attempt to delete a product as an unauthorized user	[Assert 403 Forbidden or 401 Unauthorized status code', 'Validate error message indicates insufficient permissions']	GenericProductCatalog

56	GET	/api/orders	Retrieve all orders as an administrator	['Assert 200 OK status code', 'Validate response is a JSON array of order objects', 'Verify response contains expected number of orders']	GenericOrderProcessing
57	GET	/api/orders	Retrieve own orders as an authenticated user	['Assert 200 OK status code', 'Validate response contains only orders belonging to the authenticated user', 'Verify JSON schema of order objects']	GenericOrderProcessing
58	GET	/api/orders	Attempt to retrieve all orders as an unauthenticated user	['Assert 401 Unauthorized status code', 'Validate error message indicates missing authentication']	GenericOrderProcessing
59	GET	/api/orders/{id}	Retrieve a specific order by valid ID as an administrator	['Assert 200 OK status code', 'Validate response body matches the requested order's data']	GenericOrderProcessing
60	GET	/api/orders/{id}	Retrieve own specific order by valid ID as an authenticated user	['Assert 200 OK status code', 'Validate response body matches the requested order's data']	GenericOrderProcessing

61	GET	/api/orders/{id}	Attempt to retrieve another user's order by ID as a regular authenticated user (IDOR)	['Assert 403 Forbidden or 404 Not Found status code', 'Validate error message indicates access denied']	GenericOrderProcessing
62	GET	/api/orders/{id}	Retrieve an order by a non-existent ID	['Assert 404 Not Found status code', 'Validate error message indicates order not found']	GenericOrderProcessing
63	POST	/api/orders	Create a new order with valid product IDs and quantities	['Assert 201 Created status code', 'Validate response body contains the newly created order's ID and details', 'Verify product stock levels are decremented correctly', 'Verify order can be retrieved via GET /api/orders/{id}']	GenericOrderProcessing
64	POST	/api/orders	Create an order with a non-existent product ID	['Assert 400 Bad Request status code', 'Validate error message indicates invalid product']	GenericOrderProcessing
65	POST	/api/orders	Create an order with insufficient product stock	['Assert 400 Bad Request or 409 Conflict status code', 'Validate error message indicates out of stock']	GenericOrderProcessing

66	POST	/api/orders	Create an order with invalid quantity (e.g., zero, negative)	[Assert 400 Bad Request status code', 'Validate error message indicates invalid quantity']	GenericOrderProcessing
67	POST	/api/orders	Attempt to create an order as an unauthenticated user	[Assert 401 Unauthorized status code', 'Validate error message indicates missing authentication']	GenericOrderProcessing
68	PUT	/api/orders/{id}	Update an order status to 'shipped' as an administrator	[Assert 200 OK status code', 'Validate response body reflects the updated order status', 'Verify status change is persisted']	GenericOrderProcessing
69	PUT	/api/orders/{id}	Cancel own order as an authenticated user (if order is in cancellable state)	[Assert 200 OK status code', 'Validate response body reflects the 'cancelled' status', 'Verify product stock levels are incremented back correctly']	GenericOrderProcessing
70	PUT	/api/orders/{id}	Attempt to update an order with an invalid status transition (e.g., 'shipped' to 'pending')	[Assert 400 Bad Request or 409 Conflict status code', 'Validate error message indicates invalid status transition']	GenericOrderProcessing

71	PUT	/api/orders/{id}	Attempt to update another user's order as a regular authenticated user (IDOR)	['Assert 403 Forbidden or 404 Not Found status code', 'Validate error message indicates access denied']	GenericOrderProcessing
72	PUT	/api/orders/{id}	Update an order with a non-existent ID	['Assert 404 Not Found status code', 'Validate error message indicates order not found']	GenericOrderProcessing
73	DELETE	/api/orders/{id}	Delete an order as an administrator (for cleanup/testing purposes)	['Assert 204 No Content or 200 OK status code', 'Verify order can no longer be retrieved']	GenericOrderProcessing
74	DELETE	/api/orders/{id}	Attempt to delete an order as a regular authenticated user (unauthorized)	['Assert 403 Forbidden or 401 Unauthorized status code', 'Validate error message indicates insufficient permissions']	GenericOrderProcessing

This document outlines project-specific API functional test automation for Student_Mangement_System.
Generated dynamically from source code analysis — JavaAPEX Functional Test Pipeline